

Міністерство освіти і науки України
Національний технічний університет України «Київський політехнічний інститут імені
Ігоря Сікорського»
Фізико-технічний інститут

Лабораторна робота №3

Дослідження безпечної реалізації та експлуатації децентралізованих додатків

Дисципліна: «Блокчейн та децентралізовані системи»

Виконав: ФІ-52мн Дигас Богдан

Мета роботи: «Дослідження вимог OWASP (безпека web-додатків) та складання аналогічних вимог для обраної системи децентралізованих додатків»

Список вимог OWASP Top 10 до безпеки Web-додатків

- **Broken Access Control** — неправильна або відсутня перевірка прав доступу
- **Cryptographic Failures** — слабке або відсутнє шифрування
- **Injection** — SQL, OS або інші ін'єкції через недовірені дані
- **Insecure Design** — поганий проект з точки зору безпеки
- **Security Misconfiguration** — неправильні налаштування безпеки
- **Vulnerable and Outdated Components** — небезпечні або застарілі сторонні компоненти
- **Identification and Authentication Failures** — проблеми з ідентифікацією та автентифікацією
- **Software and Data Integrity Failures** — незахищене оновлення або зміна коду
- **Security Logging and Monitoring Failures** — відсутність логування та моніторингу
- **Server-Side Request Forgery (SSRF)** — сервер виконує шкідливі зовнішні запити

Аналогічні вимоги для децентралізованого додатку (на прикладі Compound Finance)

Compound Finance — це DeFi-протокол на Ethereum, що дозволяє користувачам надавати активи в борг та брати позики під заставу. Логіка повністю реалізована у смарт-контрактах мовою Solidity.

1. Несправна перевірка доступу (Broken Access Control)

Смарт-контракти Compound мають адміністративні функції (зміна відсоткових ставок, оновлення оракулів, пауза ринків), які повинні бути доступні виключно авторизованим адресам. Якщо перевірки прав відсутні або некоректні — зловмисник може змінити параметри протоколу або вивести кошти.

Рішення:

- Використання модифікаторів `onlyAdmin`, `onlyComptroller` для обмеження доступу до критичних функцій
- Впровадження рольової моделі через `OpenZeppelin AccessControl`
- Розподіл адміністративних прав між кількома адресами через `Gnosis Safe`

2. Слабке або відсутнє шифрування (Cryptographic Failures)

Всі транзакції у `Compound` є публічними на блокчейні. Будь-які чутливі дані (наприклад, стратегії торгівлі, обсяги позицій), передані у відкритому вигляді, можуть бути використані зловмисниками для `front-running` атак.

Рішення:

- Уникати зберігання чутливих даних у відкритому вигляді на блокчейні
- Використовувати `commit-reveal` схеми для приховування намірів транзакцій
- Перевіряти підписи через `ecrecover` для верифікації дій користувача

3. Ін'єкції (Injection)

У контексті `Compound` небезпечне використання `delegatecall` або передача адрес токенів без валідації може дозволити підміну логіки контракту або взаємодію зі шкідливим токеном, що реалізує нестандартну поведінку при трансфері.

Рішення:

- Валідація всіх вхідних адрес токенів та параметрів перед виконанням
- Уникнення `delegatecall` до невідомих або динамічно переданих адрес
- Використання `SafeERC20` для захисту від нестандартних реалізацій токенів

4. Поганий проект з точки зору безпеки (Insecure Design)

Compound дозволяє брати позики під заставу. Якщо механізм ліквідації або розрахунок коефіцієнта забезпеченості спроектований з помилкою — зловмисник може через flash loan маніпулювати заставою і отримати більше, ніж вніс, не залишивши покриття.

Рішення:

- Використання TWAP (Time-Weighted Average Price) оракулів для розрахунку застави
- Проведення threat modeling на етапі проектування нових ринків
- Запровадження обмежень на максимальний обсяг позики за один блок

5. Невірні налаштування безпеки (Security Misconfiguration)

Неправильні початкові параметри ринків Compound — занадто низький collateral factor, відсутність ліміту на ліквідацію, активовані debug-функції — можуть бути використані зловмисниками для виснаження пулів ліквідності.

Рішення:

- Проводити ретельний аудит параметрів перед додаванням нових ринків
- Вимикати тестові та адміністративні функції перед розгортанням у mainnet
- Встановлювати консервативні значення collateral factor для нових активів

6. небезпечні сторонні компоненти (Vulnerable and Outdated Components)

Compound залежить від зовнішніх оракулів цін та бібліотек OpenZeppelin.

Використання застарілої версії бібліотеки або скомпрометованого оракула може призвести до некоректних розрахунків та втрати коштів.

Рішення:

- Регулярна перевірка та оновлення всіх бібліотек смарт-контрактів
- Використання кількох незалежних оракулів (Chainlink + Uniswap TWAP) для крос-перевірки цін

- Аудит залежностей перед кожним оновленням протоколу

7. Проблеми з автентифікацією (Identification and Authentication Failures)

У Compound автентифікація відбувається виключно через підпис транзакції приватним ключем. Відсутність перевірки підпису або використання застарілих підписів (replay attack) може дозволити неавторизованим особам виконувати дії від імені іншого користувача.

Рішення:

- Перевірка підписів через escrecover з обов'язковим попсо для захисту від replay-атак
- Використання апаратних гаманців (Ledger, Trezor) для зберігання приватних ключів
- Застосування multi-signature для адміністративних операцій

8. Незахищене оновлення коду (Software and Data Integrity Failures)

Якщо механізм оновлення контракту Compound (proxy pattern) не захищений належним чином — зловмисник, який отримав контроль над ключем адміністратора, може підмінити логіку контракту на шкідливу.

Рішення:

- Використання перевірених патернів оновлення (TransparentProxy або UUPS)
- Встановлення timelock не менше 48 годин для будь-яких оновлень протоколу
- Вимога кворуму в governance DAO перед застосуванням змін

9. Відсутність логування та моніторингу (Security Logging and Monitoring Failures)

Без моніторингу аномальних транзакцій атак на Compound неможливо виявити вчасно. Більшість атак на DeFi-протоколи завершуються за лічені блоки (30–60 секунд), що робить ручне реагування неефективним.

Рішення:

- Інтеграція з Forta Network або OpenZeppelin Defender для моніторингу в реальному часі
- Фіксація event при всіх критичних діях: зміна параметрів ринку, великі ліквідації, підозрілі виведення
- Впровадження механізму Pausable для екстреного призупинення роботи протоколу

10. Серверне підроблення запитів (Server-Side Request Forgery — SSRF)

Смарт-контракти Comround безпосередньо не роблять HTTP-запити, але покладаються на оракули (Chainlink), які отримують дані ззовні. Якщо зломисник маніпулює джерелом даних оракула або підміняє адресу фіду — контракт отримає хибні ціни і прийме некоректні рішення щодо ліквідацій.

Рішення:

- Використання офіційних верифікованих data feeds від Chainlink
- Введення whitelist дозволених адрес оракулів на рівні контракту
- Запровадження перевірки свіжості даних оракула (перевірка updatedAt timestamp)

Висновок

Принципи OWASP Top 10 є актуальними для децентралізованих додатків, однак вимагають переосмислення відповідно до специфіки блокчейн-систем. У Comround Finance найбільш критичними є загрози, пов'язані з некоректним контролем доступу, маніпуляцією оракулами та незахищеними механізмами оновлення — оскільки помилки у цих компонентах призводять до безповоротної фінансової втрати без можливості відкату транзакцій.